

Admin password reset



Reset lesson

1

Try to reset the password for admin.



Forgot Password?

You can reset your password here.

 email address

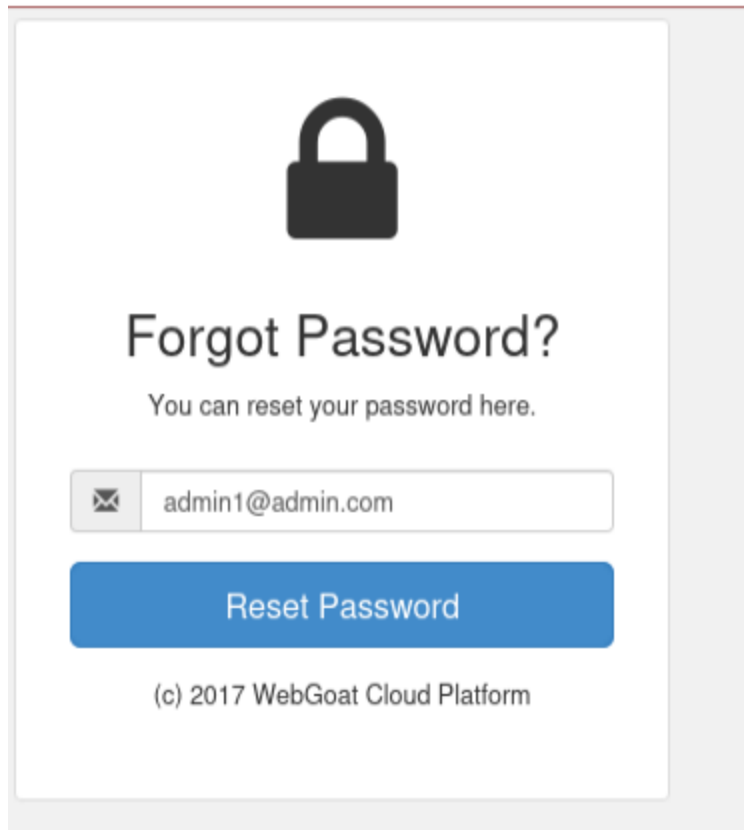
Reset Password

(c) 2017 WebGoat Cloud Platform

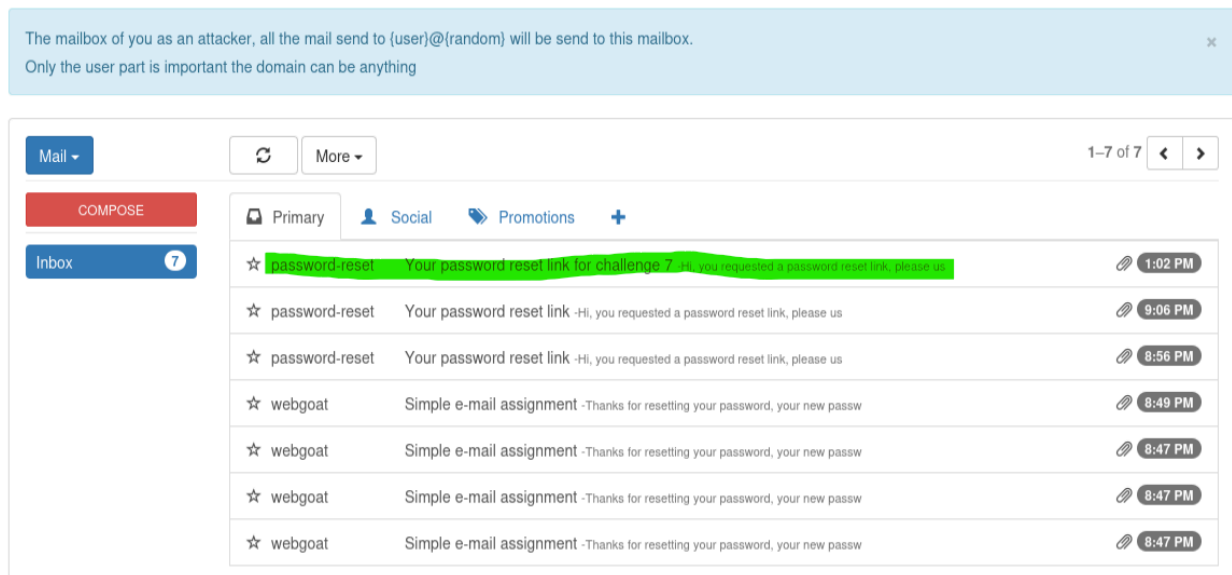
 a7179f89-906b-4fec-9d99-f15b796e7208

Submit flag

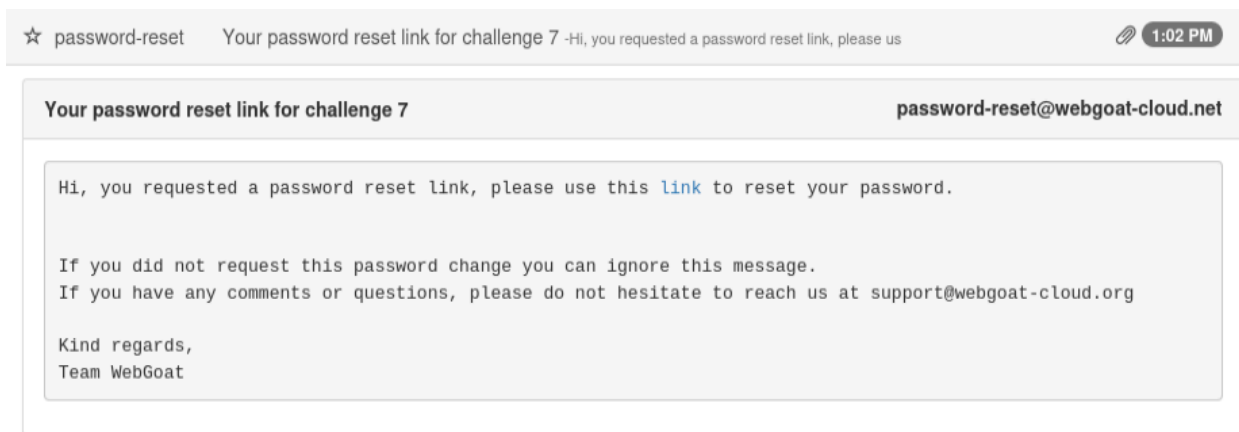
We will need to send an email to WebWolf



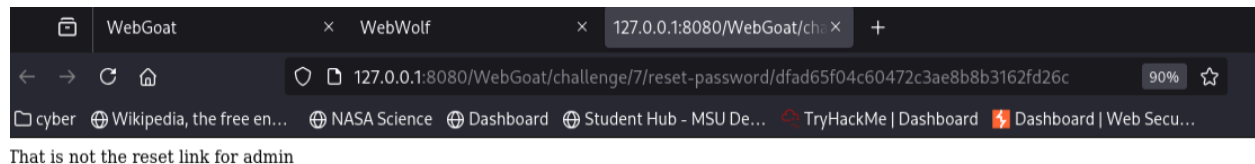
Send the password reset with username and a domain



It appears in the WebWolf inbox



Clicking the link reveals this

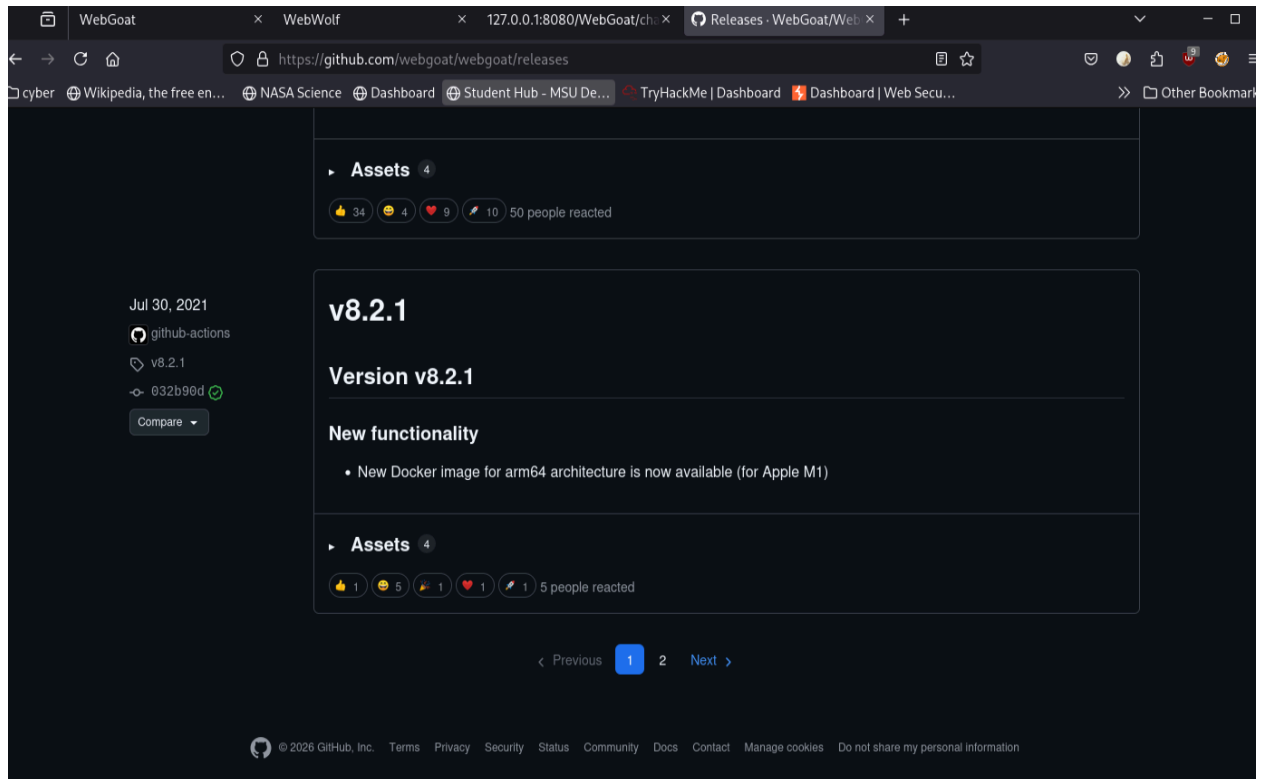


What is important is the URL

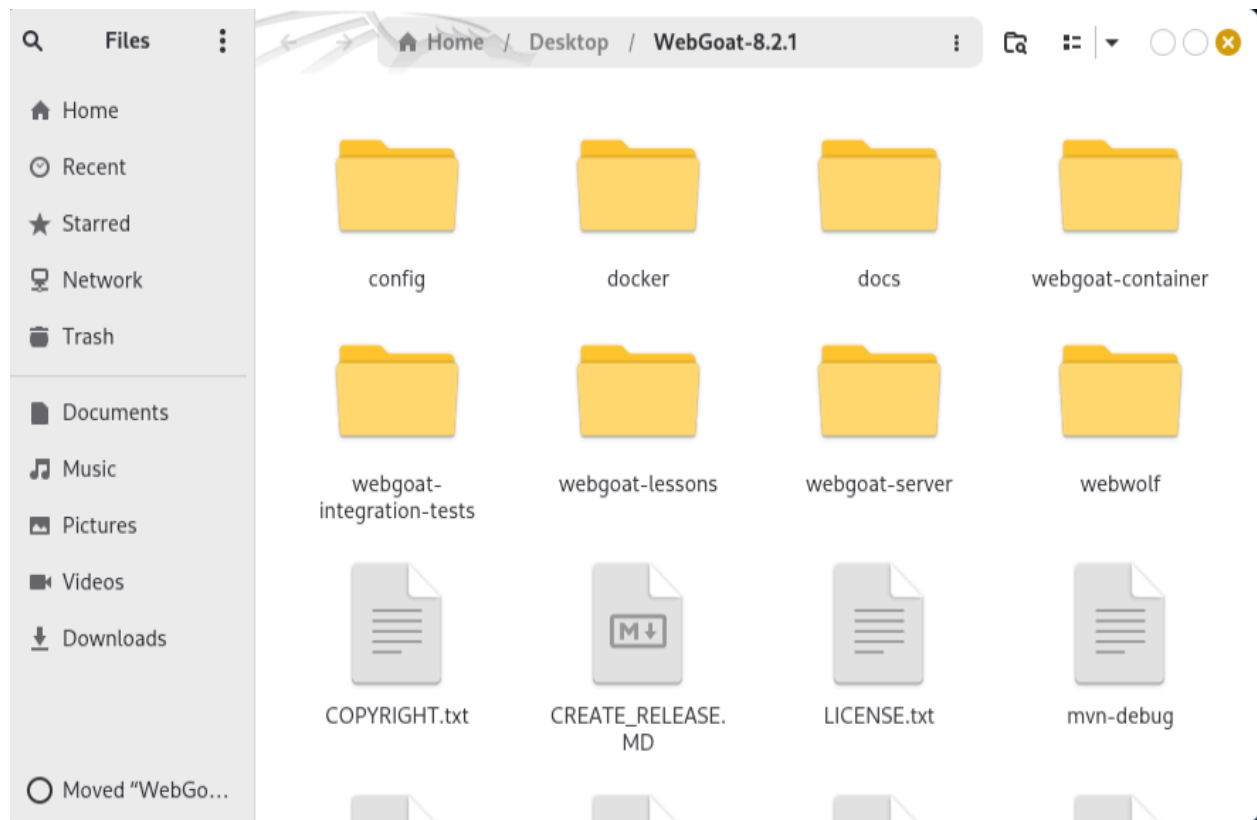
<http://127.0.0.1:8080/WebGoat/challenge/7/reset-password/dfad65f04c60472c3ae8b8b3162fd26c>

It seems like the hash value in this URL is incorrect, so we need to find one that matches the admin.

To find this, we can go into the source code for webgoat v8.2.1



I download the zip file from the github release so I can look within the folders visually



The path for this challenge is:

WebGoat-8.2.1/webgoat-lessons/challenge/src/main/java/org/owasp/webgoat/challenges/challenge7

We can find the method that's handling the feature for get requests

```

@GetMapping("/challenge/7/reset-password/{link}")
public ResponseEntity<String> resetPassword(@PathVariable(value = "link") String link) {
    if (link.equals(SolutionConstants.ADMIN_PASSWORD_LINK)) {
        return ResponseEntity.accepted().body("<h1>Success !!</h1>"
            + "<img src='/WebGoat/images/hi-five-cat.jpg'>"
            + "<br/><br/>Here is your flag: " + "<b>" + FLAGS.get(7) + "</b>");
    }
    return ResponseEntity.status(HttpStatus.I_AM_A_TEAPOT).body("That is not the reset link for admin");
}

```

The code is taking the variable link and testing if it is equal to ADMIN_PASSWORD_LINK which should be constant.

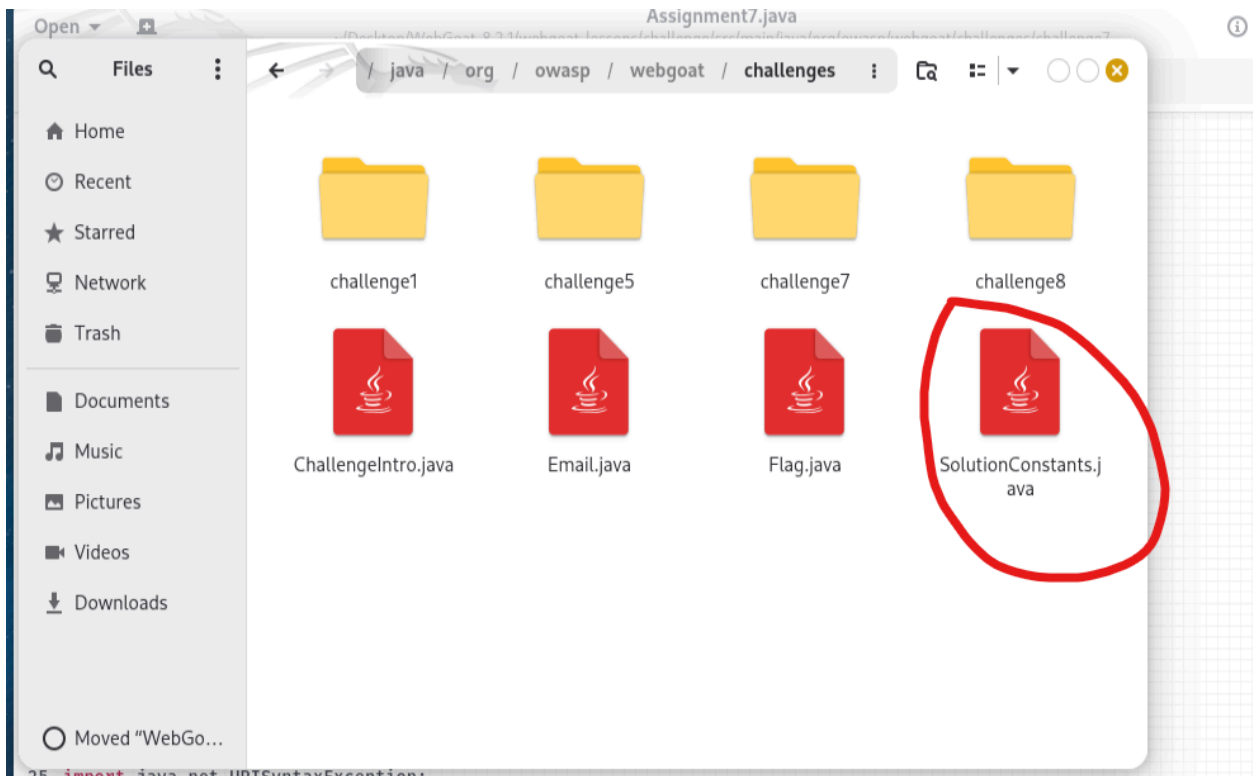
The token of the admin should be hard coded in the SolutionConstants class, if we find that it should return the flag

```

1 package org.owasp.webgoat.challenges.challenge7;
2
3 import lombok.extern.slf4j.Slf4j;
4 import org.owasp.webgoat.assignments.AssignmentEndpoint;
5 import org.owasp.webgoat.assignments.AttackResult;
6 import org.owasp.webgoat.challenges.Email;
7 import org.owasp.webgoat.challenges.SolutionConstants;
8 import org.springframework.beans.factory.annotation.Autowired;
9 import org.springframework.beans.factory.annotation.Value;
10 import org.springframework.core.io.ClassPathResource;
11 import org.springframework.http.HttpStatus;
12 import org.springframework.http.MediaType;
13 import org.springframework.http.ResponseEntity;
14 import org.springframework.util.StringUtils;
15 import org.springframework.web.bind.annotation.GetMapping;
16 import org.springframework.web.bind.annotation.PathVariable;
17 import org.springframework.web.bind.annotation.PostMapping;
18 import org.springframework.web.bind.annotation.RequestParam;
19 import org.springframework.web.bind.annotation.ResponseBody;
20 import org.springframework.web.bind.annotation.RestController;
21 import org.springframework.web.client.RestTemplate;
22

```

SolutionConstants is part of the challenges package so we can go back and find the code in the directory



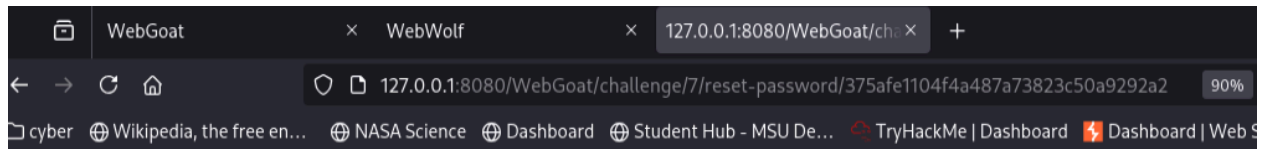
Check that code and we can see the value for ADMIN_PASSWORD_LINK



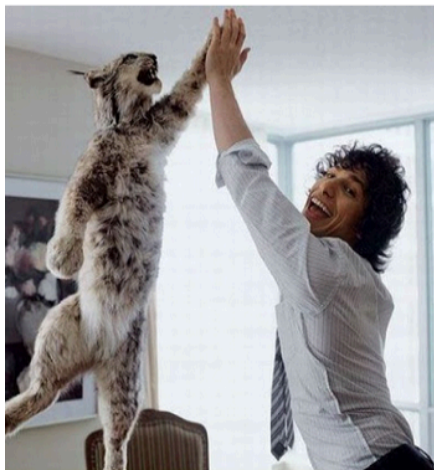
Now we can go back and change that password reset link URL to include this value:

127.0.0.1:8080/WebGoat/challenge/7/reset-password/375afe1104f4a487a73823c50a9292a2

This returns the flag



Success!!



Here is your flag: **98247c01-5ba6-46f5-abc5-0281f15dfebb**

Submit the flag

Admin password reset



Reset lesson

1

Try to reset the password for admin.

Forgot Password?

You can reset your password here.

email address

Reset Password

(c) 2017 WebGoat Cloud Platform

a7179f89-906b-4fec-9d99-f15b796e7208

Submit flag

Congratulations you have solved the challenge!!